

Lezione: ACL (Access Control List)

Introduzione

Nelle reti informatiche moderne non basta collegare dispositivi e consentire loro di comunicare. Una rete aziendale o scolastica deve anche controllare:

- quali sistemi possono comunicare;
- quali servizi possono essere utilizzati;
- quali accessi devono essere bloccati;
- quali comunicazioni devono essere consentite.

Per realizzare questi controlli vengono utilizzate le ACL, cioè Access Control List.

Le ACL costituiscono uno dei meccanismi fondamentali della sicurezza di rete.

Sono presenti in:

- router;
- switch Layer 3;
- firewall;
- sistemi operativi;
- reti WiFi;
- sistemi cloud.

Nel contesto di Sistemi e Reti le ACL vengono utilizzate soprattutto per controllare il **traffico IP tra reti differenti**.

Concetto generale di ACL

Una ACL è una struttura che contiene una lista ordinata di regole utilizzate per controllare il traffico di rete.

Ogni regola stabilisce:

- quale traffico analizzare;
- quale azione applicare;
- eventuali condizioni aggiuntive.

Le azioni principali sono:

- **permit** → consentire;
- **deny** → bloccare.

Esempio concettuale:

```
permit rete_amministrazione -> server
deny rete_ospiti -> server
permit rete_ospiti -> Internet
```

Nel caso precedente:

- la rete amministrazione può accedere ai server;
- la rete ospiti non può accedere ai server;
- la rete ospiti può uscire su Internet.

ACL come contenitore di regole

Uno degli aspetti più importanti è capire che:

- la ACL è un **contenitore** (Access Control **LIST**!!!);
- le regole appartengono alla ACL.

Molti studenti confondono:

- identificatore della ACL;
- singola regola.

In realtà:

- l'identificatore identifica l'intera ACL (LISTA);
- le regole sono gli elementi contenuti nella ACL (elementi della lista).

Struttura logica generale di una ACL

Una ACL è composta da:

- identificatore della ACL;
- una o più regole ordinate.

Ogni regola contiene generalmente:

- azione;
- sorgente;
- destinazione;
- protocollo;
- eventuali porte;
- opzioni aggiuntive.

Schema concettuale:

ACL:

identificatore = ACL_WEB

regola 1:

permit TCP
da 192.168.1.0/24
verso 10.0.0.10
porta 443

regola 2:

deny
da rete_ospiti
verso LAN_interna

Questo modello logico è comune praticamente a tutti i sistemi.

ACL e sintassi specifiche

Il concetto di ACL è generale, ma la sintassi concreta cambia a seconda del produttore o del sistema operativo.

Esempi:

Cisco IOS:

```
access-list 110 deny tcp any any eq 23
access-list 110 permit ip any any
```

NB è 1 ACL (che include 2 regole)

Linux nftables:

```
tcp dport 23 drop
```

Windows Firewall:

```
blocca TCP porta 23
```

pfSense:

```
Block TCP any -> any port 23
```

La logica è la stessa:

- bloccare Telnet.

Cambia soltanto la sintassi.

Perché le ACL sono importanti

Le ACL permettono di:

- aumentare la sicurezza;
- segmentare le reti;
- limitare accessi;
- proteggere server;
- controllare il traffico;
- ridurre propagazione malware.

Senza ACL tutte le reti potrebbero comunicare liberamente.

Questo causerebbe:

- minore sicurezza;
- maggiore superficie di attacco;
- accessi non autorizzati;
- propagazione più semplice di malware.

Come funziona una ACL

Quando un pacchetto arriva su:

- router;
- switch **Layer 3**;
- firewall;

il dispositivo:

1. legge il pacchetto;
2. confronta il traffico con le regole ACL;
3. applica la prima regola compatibile;
4. interrompe la valutazione.

Questo significa che:

- l'ordine delle regole è molto importante.

Regola implicita finale

Nella maggior parte dei sistemi esiste una regola implicita finale:

deny any

oppure:

deny ip any any

Significa:

- tutto ciò che non è esplicitamente consentito viene bloccato.

Questo approccio è fondamentale nella cybersecurity.

Tipologie di ACL

Le ACL possono essere:

- **standard** → controllano il traffico basandosi **solo sull'indirizzo IP sorgente**. Sono semplici ma poco flessibili.
- **estese** → controllano il traffico in modo più dettagliato, verificando **sorgente, destinazione, protocollo e porte TCP/UDP**. Sono le più utilizzate nelle reti moderne.

- **numerate** → vengono identificate da un **numero** (es. 10, 110). Il numero determina anche il tipo (standard o esteso).
- **nominate** → vengono identificate da un **nome testuale** (es. BLOCCA_TELNET). Sono più leggibili e più facili da gestire, soprattutto perché consentono di modificare l'ordine delle regole.
- **IPv4** → operano sugli indirizzi IP versione 4. Sono le ACL classiche ancora oggi molto diffuse.
- **IPv6** → operano sugli indirizzi IP versione 6. Per IPv6 **non esistono ACL standard**, solo ACL estese, perché il modello di sicurezza IPv6 richiede maggiore precisione.

In Cisco IOS, le ACL numerate standard usano i numeri 1-99, le ACL numerate estese usano 100-199 (e anche 2000-2699 per ACL basate su MAC sugli switch).

ACL standard

Le ACL standard controllano principalmente:

- indirizzo IP sorgente.

Sono semplici ma poco precise.

Sintassi generale ACL standard Cisco

Formato tipico:

```
access-list <numero> permit|deny <sorgente> <wildcard>
```

Esempio:

```
access-list 10 permit 192.168.10.0 0.0.0.255
access-list 10 deny any
```

Parte	Significato
access-list	comando Cisco per creare/modificare ACL
10	identificatore ACL
permit	consentire
192.168.10.0	rete sorgente
0.0.0.255	wildcard mask

Cosa significa il numero 10 Nel Cisco IOS tradizionale le ACL numerate utilizzano intervalli diversi a seconda del tipo.

Esempio:

Intervallo	Tipo ACL
1-99	ACL standard
100-199	ACL estese
2000-2699	ACL estese basate su MAC (switch "plain")

Quindi:

```
access-list 10 ...
```

indica:

- ACL standard;
- identificata dal numero 10.

Mentre:

```
access-list 110 ...
```

indica normalmente:

- ACL estesa;
- identificata dal numero 110.

Il numero NON identifica una singola regola.

Identifica l'intera ACL.

Per esempio:

```
access-list 110 permit tcp any host 10.0.0.10 eq 443
```

```
access-list 110 deny ip any any
```

significa:

- ACL numero 110;
- due regole appartenenti alla stessa ACL.

Nelle ACL **numerate** di Cisco IOS, le regole non possono essere modificate singolarmente né riordinate. Per modificare l'ordine o inserire una nuova regola in mezzo, è necessario riscrivere l'intera ACL.

Nelle ACL nominate, invece, è possibile utilizzare i numeri di sequenza (seq) per inserire, eliminare o riordinare le regole in modo flessibile.**

Wildcard mask Cisco

Nelle ACL Cisco si usa la wildcard mask.

Questa NON è una subnet mask normale.

Esempio:

Subnet mask	Wildcard
255.255.255.0	0.0.0.255
255.255.255.128	0.0.0.127

Regola:

- 0 → il bit **deve** coincidere;
- 1 → il bit **può** variare.

Quindi:

```
192.168.10.0 0.0.0.255
```

significa:

- tutti gli host della rete 192.168.10.x

cioè:

```
192.168.10.0/24
```

ACL:

```
access-list 10 permit 192.168.10.0 0.0.0.255
```

```
access-list 10 deny any
```

Prima regola:

- consentire rete 192.168.10.0/24.

Seconda regola:

- bloccare tutto il resto.

Effetto finale:

- la rete 192.168.10.0/24 è consentita;
- tutte le altre sorgenti vengono bloccate.

ACL estese

Le ACL estese permettono controlli più dettagliati.

Possono verificare:

- IP sorgente;
- IP destinazione;
- protocollo;
- porte TCP/UDP.

Sono molto più utilizzate nelle reti moderne.

Sintassi generale ACL estese Cisco

Formato generale:

```
access-list <numero> permit|deny <protocollo> <src> <dst> [porta]
```

Esempio:

```
access-list 110 permit tcp any host 10.0.0.10 eq 443
```

Parte	Significato
110	identificatore ACL estesa
permit	consentire
tcp	protocollo TCP
any	qualsiasi sorgente
host 10.0.0.10	host destinazione
eq 443	porta HTTPS

Nota: la parola chiave eq si usa solo per protocolli che utilizzano porte (TCP, UDP). Per ICMP, ad esempio, non si specifica una porta.

Effetto:

- consentire traffico HTTPS verso il server 10.0.0.10.

Significato di any e host Cisco utilizza parole chiave speciali.

- **any**: qualsiasi indirizzo IP. Equivale a: 0.0.0.0 255.255.255.255
- **host**:
‘host 10.0.0.10’ significa host specifico. Equivale a: 10.0.0.10 0.0.0.0
- **eq**: equal. Serve per specificare una porta. Esempio: ‘eq 443’ significa: porta 443.

ACL numerate e nominate

Le ACL possono essere:

- numerate;
- nominate.

ACL numerata:

```
access-list 110 permit tcp any any eq 80
```

ACL nominata:

```
ip access-list extended WEB_FILTER
```


permit tcp any any eq 80

Le ACL nominate sono:

- più leggibili;
- più semplici da gestire;
- più professionali.

Nelle ACL nominate è possibile modificare l'ordine delle regole usando i numeri di sequenza, cosa non possibile nelle ACL numerate tradizionali.

ACL inbound e outbound

Le ACL possono essere applicate:

- inbound: il traffico viene controllato quando entra nell'interfaccia.
- outbound: il traffico viene controllato quando esce.

Esempio inbound

Schema:

PC -> Router -> Server

ACL inbound:

- il traffico viene filtrato appena entra nel router.

Questo riduce:

- traffico inutile;
 - carico del dispositivo.
-

ACL nei router

Nei router le ACL vengono utilizzate per:

- filtrare traffico;
- separare reti;
- limitare servizi;
- controllare accessi.

Esempio:

- VLAN studenti;
- VLAN docenti;
- VLAN server.

Possibili regole:

- studenti non possono accedere ai server amministrativi;
 - docenti sì;
 - studenti possono solo navigare.
-

ACL negli switch Layer 3

Gli switch Layer 3 possono eseguire routing tra VLAN.

Le ACL vengono spesso applicate alle SVI (Switch Virtual Interface).

Esempio:

```
interface vlan 10
```

```
ip access-group STUDENTI in
```

Significato:

Parte	Significato
interface vlan 10	configurazione VLAN 10
ip access-group	applica ACL
STUDENTI	nome ACL
in	direzione inbound

ACL nei firewall

I firewall utilizzano ACL molto evolute.

Possono controllare:

- IP;
- porte;
- protocolli;
- applicazioni;
- utenti;
- contenuti.

NB: un firewall **tradizionale** usa **ACL basate su IP/porta**.

Un **Next Generation Firewall (NGFW)** può invece bloccare social network, permettere Teams, limitare streaming e identificare malware tramite **ispezione applicativa (Layer 7)**.

Casi d'uso reali

Le ACL vengono continuamente utilizzate nelle reti aziendali.

Esempio:

- VLAN amministrazione;
- VLAN sviluppo;
- VLAN ospiti.

Possibili regole:

- ospiti → solo Internet;
- sviluppo → server Git;
- amministrazione → gestionale.

Protezione dei server

Le ACL permettono di proteggere server.

Esempio:

```
permit HTTPS verso web server
deny tutto il resto
```

Questo riduce la superficie di attacco.

ACL e reti WiFi

Le ACL sono molto usate nelle reti wireless.

Esempio:

- rete aziendale;
- rete ospiti.

La rete ospiti deve:

- uscire su Internet;
- non accedere alla LAN interna.

Questa separazione viene spesso implementata tramite:

- VLAN;
- ACL;
- firewall.

ACL e principio del minimo privilegio

Le ACL devono rispettare il principio del minimo privilegio.

Significa:

- consentire solo ciò che è necessario.

Esempio scorretto:

```
permit ip any any
```

Questa regola permette praticamente tutto.

Errori comuni

Gli errori più comuni sono:

- ordine errato delle regole;
- ACL troppo permissive;
- ACL troppo restrittive;
- dimenticanza DNS;
- blocco DHCP;
- mancanza di documentazione.

Esempio errato:

```
deny any  
permit rete_server
```

La seconda regola non verrà mai raggiunta.

ACL e troubleshooting

Quando una comunicazione non funziona bisogna verificare:

- IP;
- gateway;
- routing;
- DNS;
- ACL.

Molti problemi derivano da ACL errate.

Strumenti utili:

- ping;
- tracer/tracepath;
- Wireshark;
- log firewall;
- show access-list.

Implementazione tipica in Sistemi e Reti

In una rete scolastica o aziendale:

- ogni reparto usa una VLAN;
- lo switch Layer 3 esegue routing;
- ACL controllano comunicazioni tra VLAN.

Esempio:

VLAN studenti:

- accesso Internet
- accesso Moodle

VLAN amministrazione:

- accesso gestionale
- accesso server documenti

VLAN ospiti:

- solo Internet

Questa architettura è molto diffusa.

Laboratorio semplice con Packet Tracer

Sito ufficiale: <https://www.netacad.com/>

Laboratorio rapido:

1. creare:
 - 2 PC;
 - 1 switch Layer 3;
 - 1 server.
2. creare:
 - VLAN 10;
 - VLAN 20.
3. configurare:
 - indirizzi IP;
 - gateway.
4. verificare:
 - ping funzionante.
5. applicare ACL:
 - bloccare VLAN10 verso server.
6. verificare:
 - ping bloccato.

Durata tipica:

- 20-30 minuti.

Laboratorio con Windows Firewall

Windows Defender Firewall permette di realizzare ACL semplificate.

Procedura:

1. aprire:
 - Windows Defender Firewall con sicurezza avanzata.

2. creare:

- nuova regola.

3. selezionare:

- TCP;
- porta.

4. bloccare:

- 3389;
- oppure 80.

Questo laboratorio è molto semplice e veloce.

Laboratorio con pfSense

pfSense è un firewall open source.

Sito ufficiale:

<https://www.pfsense.org/>

Può essere installato:

- VirtualBox;
- VMware;
- hardware reale.

Permette di comprendere ACL reali in ambiente grafico.

Conclusioni

Le ACL rappresentano uno degli strumenti fondamentali della sicurezza di rete.

Permettono di:

- filtrare traffico;
- proteggere server;
- separare VLAN;
- limitare accessi;
- implementare policy di sicurezza.

Il concetto logico di ACL è universale:

permit oppure deny
in base a determinate condizioni

La sintassi invece dipende dal produttore:

- Cisco;
- Linux;
- Windows;
- pfSense;
- firewall enterprise.

Alcuni riferimenti

Cisco ACL Overview <https://www.cisco.com/c/en/us/support/docs/security/ios-firewall/23602-confaccesslists.html>

Cisco Packet Tracer <https://www.netacad.com/resources/lab-downloads>

pfSense <https://www.pfsense.org/>

Microsoft Windows Defender Firewall <https://learn.microsoft.com/en-us/windows/security/operating-system-security/network-security/windows-firewall/>

Wireshark <https://www.wireshark.org/>

